

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
1	Identificar e autenticar todo usuário antes de qualquer acesso a dados com identificação do beneficiário.	Obrigatório	out/12		ago/14	
2	Utilizar para autenticação de usuários a site e páginas da Internet (portais) login e senha podendo opcionalmente, desde que acordado entre as partes, ser utilizada a certificação digital.	Obrigatório	out/12		ago/14	
3	Utilizar para autenticação de usuários, via utilização de webservices, login e senha podendo opcionalmente, desde que acordado entre as partes, ser utilizada a certificação digital em substituição ao login e senha.	Obrigatório	out/12		ago/14	
12	Utilizar certificado digital sempre dentro do período de validade além de não aceitar o certificado se o mesmo estiver na lista de certificados revogados da AC.	Obrigatório	out/12		ago/14	
13	Utilizar certificado digital que identifique o endereço eletrônico para o qual foi emitido	Obrigatório	out/12		ago/14	
14	Utilizar certificado digital que contemple em sua estrutura a identificação da autoridade certificadora emissora.	Obrigatório	out/12		ago/14	
15	Utilizar certificado digital que contemple em sua estrutura a identificação do titular do certificado	Obrigatório	out/12		ago/14	
18	Utilizar certificado digital que implemente autenticação por algoritmo HASH	Obrigatório	out/12		ago/14	
30	Deve conter a assinatura digital do prestador de serviços na mensagem enviada à operadora para assegurar a autenticidade, o não repúdio, a integridade e a garantia de origem.	Recomendado	jan/18			

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
31	Deve conter a assinatura digital da operadora na mensagem enviada ao prestador de serviços para assegurar a autenticidade, a integridade do conteúdo e o não repúdio das informações ali contidas.	Recomendado	jan/18			
34	A sessão de comunicação remota entre cliente e servidor deve possuir controles de segurança que impeçam o roubo ou reuso da sessão do usuário. a) As credenciais de acesso não devem ser transmitidas entre as partes na forma de texto claro. b) Devem haver controles que impeçam o reuso de identificadores de sessão do usuário (por exemplo: ataques de replay e covert-channel) e roubo da sessão. c) Não deve ser possível para qualquer usuário do sistema desativar ou desabilitar tais controles.	Obrigatório	jan/18		dez/18	
35	Utilizar certificado digital que utilize criptografia de, no mínimo, 256 bits.	Obrigatório	jan/18		dez/18	

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
36	O sistema deve apresentar minimamente as informações de identificação do software, contendo obrigatoriamente o nome do software, nome do fornecedor, identificação completa da versão e/ou release e/ou build. Essas informações deverão estar disponíveis minimamente: • na tela inicial do sistema; • nas telas de cada módulo de modo que quando o sistema esteja em uso essas informações estejam sempre visíveis; • impressões geradas oriundas do sistema.	Obrigatório	jan/18		dez/18	
37	Todo usuário do sistema deve ser identificado e autenticado antes de qualquer acesso a dados ou funcionalidades do sistema.	Obrigatório	jan/18		dez/18	
38	Utilizar, nos processos de autenticação de usuário para acesso aos sistemas, um dos seguintes métodos: • Identificação de usuário e senha secreta de acesso; • Certificado digital; • Validação biométrica; • OTP.	Obrigatório	jan/18		dez/18	

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
41	a) Identidade única: toda pessoa usuária do sistema deverá ser identificada individualmente. b) Vinculação a número legal e único: toda pessoa usuária do sistema deverá ser vinculada minimamente a um documento de identificação pessoal unívoco. c) Unicidade de identificação de usuários: a informação de identificação de tal documento deverá ser validada na inclusão ou alteração de pessoas para garantir a unicidade, ou seja, o sistema não deve permitir a associação de um mesmo documento de identificação a dois usuários no sistema. d) Exclusão de usuários: Para fins de responsabilização, não deve ser possível remover o cadastro ou vínculo de usuários e profissionais de saúde do sistema, caso alguma operação tenha sido realizada pelo mesmo. Que seja possível inativar usuário, apesar de não poder excluir, e que o inativo não consiga fazer login/acessar.	Obrigatório	jan/18		dez/18	
42	Assim que completada uma autenticação com sucesso, o sistema deve exibir à pessoa usuária as seguintes informações: • Data e hora da última autenticação com sucesso de seu usuário; • Data e hora das tentativas de autenticação sem sucesso depois da última autenticação com sucesso. Nota: Considera-se como “última autenticação” a autenticação anterior à que está ocorrendo.	Obrigatório	jan/18		dez/18	

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
43	Condição: Arquitetura cliente-servidor e autenticação por login e senha. A interface de usuário utilizada para digitação de credenciais de acesso ao sistema (login ou nome do usuário, senha secreta de acesso, PIN) deve impedir a memorização e a visualização de dados anteriores (lista de logins já digitados, lembrança automática de senhas associadas a um login, etc.). Além disso, toda e qualquer digitação direta de senhas deve ser feita por meio de máscara de caracteres que impeça sua visualização por outras pessoas.	Obrigatório	jan/18		dez/18	
44	Impedir acesso ou visualização dos dados por pessoas não autorizadas no sistema.	Obrigatório	jan/18		dez/18	
45	Garantir que o acesso aos dados do sistema seja somente possível por meio de canais de interação pré-definidos (ex.: web, console local, interface entre aplicativos), com atuação obrigatória de mecanismos de controle de acesso.	Obrigatório	jan/18		dez/18	
46	a) A sessão de comunicação entre o componente de interação com o usuário (ex.: browser ou executável cliente) e os outros componentes do sistema (ex.: aplicação) deve oferecer os seguintes funcionalidades de segurança: autenticação, integridade dos dados e confidencialidade dos dados. b) O componente de segurança empregado deve implementar criptografia na comunicação utilizando algoritmo de, no mínimo, 256 bits.	Obrigatório	ago/21		abr/23	

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
49	Os dados inseridos pelo usuário nos campos de entrada (inputs, caixas de texto, etc) devem ser validados antes de serem processados, de forma a prevenir ataques de buffer overflow e injeção de dados.	Obrigatório	jan/18		dez/18	
50	O sistema deve permitir o gerenciamento (criação, ativação/inativação e modificação) de usuários e papéis (perfis), por meio da aplicação, de forma a possibilitar o controle de acesso às funcionalidades do sistema conforme os papéis aos quais o usuário possui. Um usuário pode possuir um ou mais papéis.	Obrigatório	jan/18		dez/18	
51	Em caso de autenticação inválida em tentativa de acesso, a mensagem de erro emitida pelo sistema para o usuário não deve informar qual o motivo do erro.	Obrigatório	jan/18		dez/18	
53	Todos os processos de validação das regras de negócio (ex.: validação de dados, conteúdo, tamanho, domínio, etc.) devem ser realizados no back-end. Opcionalmente, poderá haver tais validações no front-end, desde que seguidas das validações no back-end.	Obrigatório	ago/21		abr/23	
54	A arquitetura do sistema deverá estar disposta em camadas e seus componentes distribuídos. O banco de dados deverá estar segregado das aplicações (ex.: componentes, segmentos de rede, API).	Recomendado	jan/18			

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
55	O acesso de usuários ao SGBD deve ser permitido somente por intermédio do componente de autenticação e controle de acesso com usuário exclusivo para esse fim, exceto nas atividades de cópia de segurança (suporte de maneira geral).	Recomendado	jan/18			
56	Componentes que manipulam dados identificados do sistema para fins de interoperabilidade, visualização, assinatura e outros, não devem manter tais dados fora do SGBD após o término da operação.	Obrigatório	ago/21		abr/23	
57	Gerar trilhas de auditoria das ações realizadas no tratamento de dados pessoais e pessoais sensíveis.	Obrigatório	ago/21		abr/23	
58	Os registros de auditoria gerados devem ter garantia de integridade e serem protegidos contra acesso não autorizado.	Obrigatório	ago/21		abr/23	
59	O sistema deve possuir uma interface para visualização dos registros de auditoria em ordem cronológica.	Recomendado	jan/18			
60	Toda pessoa usuária do sistema deve ter a autenticação confirmada no momento da realização de operações críticas ou sensíveis, mesmo que já tenha se autenticado previamente para ingresso ao sistema.	Recomendado	jan/18			
62	As bases de dados, mídias ou arquivos que contém dados pessoais e/ou dados pessoais sensíveis devem ser protegidas para garantir a confidencialidade (por exemplo: criptografia, somente acessos autorizados, etc.)	Obrigatório	ago/21		abr/23	

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
63	Utilização de captcha na tela de acesso ao sistema vinculada ao método de autenticação por login e senha. Não deve ser permitido autenticar o usuário sem a validação simultânea do login, senha e token do captcha.	Recomendado	ago/21			
64	Adotar a criptografia de, no mínimo, 256 bits na comunicação entre as partes da aplicação em redes distintas.	Recomendado	ago/21			
65	Utilização de captcha na tela de recuperação de senha de acesso do sistema para evitar ataques do tipo Brute Force	Recomendado	ago/21			
66	Não permitir alterar e remover registros do log de auditoria de sistema por um tempo mínimo de 90 dias	Obrigatório	ago/21	jun/26	abr/23	Será substituído pelo requisito 85
67	Mínimo de 08 caracteres utilizando pelo menos um (01) caractere de cada um dos quatro (4) tipos de caracteres listados abaixo: • Letras Maiúsculas (AZ) • Letras Minúsculas (az) • Números (0-9) • Símbolos ASCII (~! @ # \$% ^ & * () _ + - = {} \:"; '<>?,. / e espaço) e caracteres Unicode.	Obrigatório	ago/21		abr/23	
68	Definir o período máximo de troca de senha como controle do sistema. Este período não deve ser superior a 180 (cento e oitenta dias). O sistema deve permitir que o usuário troque sua senha a qualquer momento.	Obrigatório	ago/21	jun/26	abr/23	Será substituído pelo requisito 81

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
69	Bloquear, ao menos temporariamente, o usuário após um número máximo de tentativas inválidas de login, por qualquer meio de acesso. Este número de tentativas não deve ser superior a cinco. Após o número máximo de tentativas, o usuário poderá ser bloqueado por, no mínimo, 5 (cinco) minutos ou ser submetido a outros controles para autenticação. O desbloqueio será feito apenas pelo próprio usuário ou a sessão será encerrada.	Obrigatório	ago/21		abr/23	
70	Registrar log de acessos e de tentativas de acesso ao sistema de informação. O tempo de armazenamento desta informação seja de, no mínimo, 90 (noventa) dias.	Obrigatório	ago/21	jun/26	abr/23	Será substituído pelo requisito 84
71	Utilizar certificado digital que utilize apenas protocolo criptográfico TLS na versão mínima 1.2.	Obrigatório	ago/21		abr/23	
72	A interrupção do serviço de troca eletrônica de informações entre prestadores de serviços de saúde e operadoras de planos privados de assistência à saúde deve ser solucionada em até 48 (quarenta e oito) horas corridas, salvo em caso fortuito ou de força maior devidamente justificado.	Obrigatório	ago/21		abr/23	
73	As operadoras de planos privados de assistência à saúde devem constituir proteções administrativas, técnicas e físicas para impedir o acesso não autorizado à dados pessoais e dados pessoais sensíveis.	Obrigatório	ago/21		abr/23	

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
74	Os prestadores de serviços de saúde devem constituir proteções administrativas, técnicas e físicas para impedir o acesso não autorizado à dados pessoais e dados pessoais sensíveis, em especial à toda informação identificada individualmente.	Obrigatório	ago/21		abr/23	
75	Igualdade de senha: os processos de troca de senha devem exigir que a nova senha seja diferente das três últimas senhas utilizadas pelo usuário.	Obrigatório	ago/21	jun/26	abr/23	Será substituído pelo requisito 82
76	a) A sessão de usuário deve ser automaticamente bloqueada ou encerrada forçadamente pelo aplicativo após um período de inatividade. Este tempo não deve ser superior a 30 minutos. b) Após o bloqueio ou encerramento da sessão de usuário, as informações em tela não deverão mais estar visíveis, sendo necessária uma nova autenticação para a retomada da atividade. c) Não deve ser possível para qualquer usuário do sistema desativar ou desabilitar tais controles. d) Para que o desbloqueio de sessão seja realizado, o sistema deve requerer novo processo de autenticação do usuário bloqueado.	Obrigatório	ago/21	jun/26	abr/23	Será substituído pelo requisito 83

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
77	Armazenar de forma protegida todos os dados ou parâmetros utilizados no processo de autenticação de usuário. Método: Nome de usuário e senha a) A senha deve ser armazenada em banco de dados, de forma codificada por algoritmo criptográfico no mínimo igual a 256 bits. b) As codificações das senhas de acesso dos usuários devem ser protegidas contra acesso não autorizado. Método: Biometria (condição: somente para pessoas) c) Os templates biométricos das pessoas devem ser protegidos contra acesso não autorizado. d) As amostras biométricas coletadas e transmitidas durante o processo de autenticação devem ser protegidas contra acesso não autorizado. Método: OTP e) As sementes de geração dos valores devem ser protegidas contra acesso não autorizado.	Obrigatório	ago/21		abr/23	
78	A comunicação entre componentes distribuídos do sistema (como por exemplo, entre a aplicação e o banco de dados) devem oferecer controles de segurança para impedir acesso não autorizado. Para tal, deverão ser utilizados componentes de segurança que garantam a autenticação e a confidencialidade entre as partes da aplicação e a integridade dos dados.	Obrigatório	ago/21		abr/23	

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
79	Dados pessoais e pessoais sensíveis estruturados devem ser armazenados por Sistema(s) de Gerenciamento de Banco de Dados (SGBD) e dados pessoais e pessoais sensíveis não estruturados e não armazenados em SGBD devem atender à requisitos de confidencialidade.	Obrigatório	ago/21		abr/23	
80	Para as transmissões remotas de dados identificados, os sistemas das operadoras de planos de saúde deverão possuir um certificado digital de servidor emitido por uma Autoridade Certificadora. AC certificados de servidor homologada WebTrust for CAs, WebTrust for CAs - SSL Baseline with Network Security , e ETSI TS 102 042, ETSI EN 319 411-1 e ETSI EN 319 411-2 .	Obrigatório	ago/21		abr/23	
81	Definir o período máximo de troca de senha como controle do sistema. Este período não deve ser superior a 90 (noventa dias). O sistema deve permitir que o usuário troque sua senha a qualquer momento.	Obrigatório	dez/25		jun/26	
82	Igualdade de senha: os processos de troca de senha devem exigir que a nova senha seja diferente das dez últimas senhas utilizadas pelo usuário.	Obrigatório	dez/25		jun/26	

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
83	a) A sessão de usuário deve ser automaticamente bloqueada ou encerrada forçadamente pelo aplicativo após um período de inatividade. Este tempo não deve ser superior a 10 (dez) minutos. b) Após o bloqueio ou encerramento da sessão de usuário, as informações em tela não deverão mais estar visíveis, sendo necessária uma nova autenticação para a retomada da atividade. c) Não deve ser possível para qualquer usuário do sistema desativar ou desabilitar tais controles. d) Para que o desbloqueio de sessão seja realizado, o sistema deve requerer novo processo de autenticação do usuário bloqueado.	Obrigatório	dez/25		jun/26	
84	Registrar log de acessos e de tentativas de acesso ao sistema de informação. O tempo de armazenamento dessa informação será de, no mínimo, 180 (cento e oitenta) dias.	Obrigatório	dez/25		jun/26	

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
85	As soluções que operam com dados do padrão TISS deverão manter registros de logs de auditoria completos, estruturados e auditáveis, contendo: identificação do usuário ou sistema, data e hora de acesso, dados acessados, tipo de operação realizada (consulta, inserção, alteração ou exclusão) e finalidade declarada do uso da informação. O log deve estar disponível para auditoria por parte da ANS e do titular dos dados quando solicitado por um tempo mínimo de 180 (cento e oitenta) dias, não sendo permitido alterar e/ou remover seus registros durante esse período. O tempo mínimo descrito acima não desconsidera os demais prazos para manutenção dos dados e respectivos metadados previstos na legislação que dispõe sobre a digitalização e a utilização de sistemas informatizados para a guarda, o armazenamento e o manuseio de prontuários clínicos.	Obrigatório	dez/25		jun/26	
86	Quando utilizar o método "Nome de Usuário e Senha" no processo de autenticação, empregar um segundo fator de autenticação que consista em chave constituída por uma sequência de caracteres alfabéticos e/ou numéricos únicos enviados para o e-mail ou número celular do usuário cadastrado. Esse segundo fator deverá ser solicitado, no mínimo, no primeiro acesso do usuário no dia e, no máximo, em todas as seções de acesso.	Recomendado	dez/25			

Requisitos de segurança e privacidade do padrão TISS vigentes no Padrão TISS - Novembro de 2025

Escopo Os requisitos que compõem esta relação, se aplicam a todos os sistemas e portais que tratam os dados que fazem parte do Padrão TISS para troca de informações na saúde suplementar.



Numeração	Descrição	Condição de utilização	Início de vigência	Fim de Vigência	Data limite para implantação	OBS
87	Quando utilizar o método "Nome de Usuário e Senha" no processo de autenticação, empregar um segundo fator de autenticação que consista em chave constituída por uma sequência de caracteres alfabéticos e/ou numéricos únicos enviados para o e-mail ou celular do usuário cadastrado quando este alterar o próprio e-mail ou número do celular.	Recomendado	dez/25			